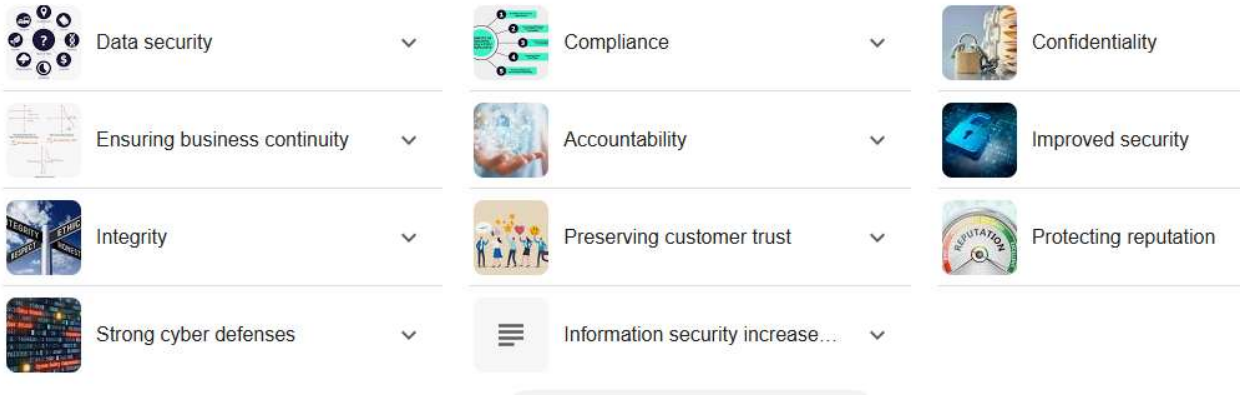
Lecture5: Information System Security (IIS) (Dr. Abdusalam Yahya)

التعريف : يشير أمن نظم المعلومات (ISS) إلى العمليات والممارسات المصممة لحماية نظم المعلومات في المؤسسة من الوصول غير المصرح به، والاستخدام، والتعطيل، والتعديل، أو التدمير.وذلك عن طريق تحقيق النقاط الاتية :-

1. السرية .
2. سلامة البيانات
3. النوافرية .

- **أهمية الحماية لأنظمة المعلومات**



-

2 . المفاهيم الأساسية في أمن نظم المعلومات.

لكى نحدد على نظام المعلومات أمن أم لا يجب التحقق من تطبيق النقاط التالية

- **السرية : يجب أن تكون المعلومات الحاسة الخاصة بالنظام** متاحة فقط للأشخاص المصرح لهم.
- **النزاهة** يجب الحفاظ على دقة واكتمال البيانات، وضمان عدم تعديلها أو العبث بها.
- **التوافر** : يجب أن يكون نظام المعلومات متاحة للمستخدمين المصرح لهم عند الحاجة.

3. مكونات أمن نظام المعلومات

- **التحكم في الوصول:**
  - آليات لتقييد الوصول إلى نظم المعلومات.
  - تشمل الأنواع :
    - **المصادقة** :التحقق من هوية المستخدمين (مثل كلمات المرور، والبيانات البيومترية).
    - **التفويض** :منح الأذونات للمستخدمين بناءً على أدوارهم.
- **أمن الشبكات:**
  - حماية البيانات أثناء النقل عبر الشبكات.
  - تشمل التقنيات الجدران النارية، وأنظمة اكتشاف التسلل، والشبكات الخاصة الافتراضية (VPN).
- **أمن التطبيقات:**
  - حماية التطبيقات البرمجية من الثغرات والتهديدات.
  - تشمل الممارسات البرمجة الآمنة، والتحديثات المنتظمة، وتقييم الثغرات.
- **الأمن الفيزيائي:**
  - حماية الأصول الفيزيائية، بما في ذلك الخوادم ومراكز البيانات، من الوصول غير المصرح به والمخاطر البيئية.
  - تشمل التدابير المراقبة، والأقفال، والضوابط البيئية.

---

4. التهديدات لأمن نظم المعلومات

- **البرمجيات الخبيثة** :برامج مصممة لتعطيل، أو إتلاف، أو الوصول غير المصرح به إلى الأنظمة (مثل الفيروسات، وبرامج الفدية).
- **التصيد الاحتيالي** :هجمات الهندسة الاجتماعية تهدف إلى خداع المستخدمين لكشف معلومات حساسة.
- **التهديدات الداخلية** :المخاطر التي يمثلها الموظفون أو المتعاقدون الذين لديهم وصول مشروع إلى الأنظمة.
- **هجمات الحرمان من الخدمة :(DoS)** هجمات تهدف إلى جعل نظام أو خدمة غير متاحة للمستخدمين.

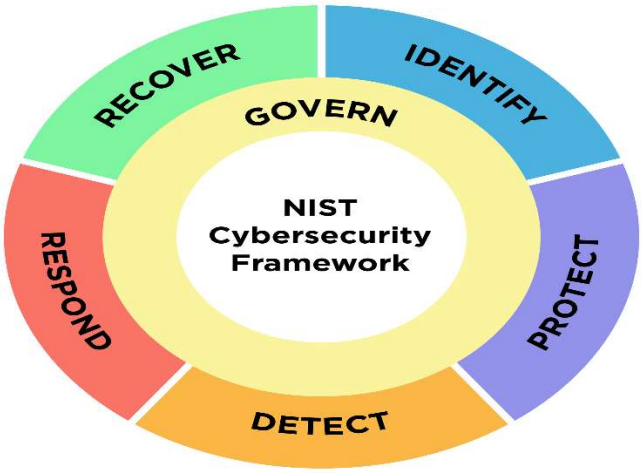
---

5. استراتيجيات وممارسات أمن نظم المعلومات

- **تقييم المخاطر:**
  - تحديد وتقييم المخاطر التي تواجه نظم المعلومات.

- تحديد أولويات المخاطر بناءً على التأثير المحتمل والاحتمالية.

- **التخطيط للاستجابة للحوادث:**
  - تطوير خطط للاستجابة للاختراقات الأمنية والحوادث .
  - تشمل خطوات الكشف، والاحتواء، والقضاء، والتعافي.
- **تدريب.. التوعية الأمنية:**
  - تعليم الموظفين حول أفضل الممارسات الأمنية والتهديدات المحتملة.
  - يساعد التدريب المنتظم في خلق ثقافة واعية تساعد في تعزيز الامن .
- **المراجعات والامتثال المنتظم:**
  - إجراء مراجعات أمنية لتقييم فعالية التدابير الأمنية.
  - ضمان الامتثال للمعايير واللوائح الصناعية **NIST Cybersecurity Framework**



مقارنة بين أمن المعلومات، والأمن السيبراني، وأمن الشبكات

1.تعريفات

- **أمن المعلومات:**
  - يشمل حماية المعلومات من الوصول غير المصرح به، والكشف، والتعديل، والتدمير. يركز على كافة أشكال المعلومات سواء كانت رقمية أو ورقية.
- **الأمن السيبراني:**
  - يركز على حماية الأنظمة والشبكات والبرمجيات من الهجمات الرقمية. يهدف إلى حماية البيانات والمعلومات من التهديدات التي تأتي من الإنترنت.
- **أمن الشبكات:**

- يتخصص في حماية شبكات الحاسوب من المهاجمين، سواء كانوا مستهدفين بيانات أو خدمات. يشمل تقنيات مثل الجدران النارية، وأنظمة كشف التسلل.

---

2. النطاق

- **أمن المعلومات:**
  - نطاقه شامل، يغطي جميع أنواع المعلومات في أي شكل، بما في ذلك البيانات المخزنة في قواعد البيانات، والمعلومات الورقية.
- **الأمن السيبراني:**
  - نطاقه محدد أكثر، يركز بشكل خاص على التهديدات التي تأتي من الفضاء السيبراني (الإنترنت).
- **أمن الشبكات:**
  - نطاقه أضيق، يركز على حماية الشبكات نفسها، بما يشمل الأجهزة، والبرمجيات، والبيانات أثناء نقلها عبر الشبكات.

---

3. الأهداف

- **أمن المعلومات:**
  - الحفاظ على سرية، ونزاهة، وتوافر المعلومات.
- **الأمن السيبراني:**
  - حماية الأنظمة والمعلومات من الهجمات، وتقليل المخاطر السيبرانية.
- **أمن الشبكات:**
  - منع الوصول غير المصرح به إلى الشبكات والبيانات المنقولة عبرها.

أمن قواعد بيانات نظم المعلومات

أمن قواعد البيانات هو جزء أساسي من أمان نظم المعلومات، حيث يهدف إلى حماية البيانات المخزنة في قواعد البيانات من الوصول غير المصرح به، والتلاعب، والتدمير. تعتبر قواعد البيانات مركزًا حيويًا لتخزين المعلومات الحساسة.

2. أهمية أمن قواعد البيانات

- **حماية البيانات الحساسة** :تشمل المعلومات الشخصية والمالية، مما يتطلب تدابير أمان قوية.
- **الامتثال** :تلبية المتطلبات القانونية والتنظيمية مثل GDPR و.HIPAA
- **حماية سمعة المؤسسة** :أي خرق للبيانات يمكن أن يؤثر سلبًا على سمعة المؤسسة وثقة العملاء.

---

3. التهديدات الامنية لقواعد البيانات

- **الهجمات الخارجية** :مثل هجمات SQL injection التي تستهدف الثغرات في استعلامات قاعدة البيانات.
- **التهديدات الداخلية** :الموظفون الذين لديهم وصول مشروع قد يستغلون بيانات حساسة.
- **البرمجيات الخبيثة** :البرامج التي تهدف إلى سرقة أو تدمير البيانات.

---

4. استراتيجيات أمن قواعد البيانات

- **التحكم ي الوصول:**
  - تنفيذ مستويات مختلفة من الوصول للمستخدمين بناءً على الأدوار.
  - استخدام المصادقة القوية (مثل كلمات المرور المعقدة، والتحقق الثنائي).
- **التشفير:**
  - تشفير البيانات المخزنة والبيانات المنقولة لحمايتها من الوصول غير المصرح به.
- **المراقبة والتسجيل:**
  - تتبع الأنشطة في قواعد البيانات للكشف عن أي سلوك غير عادي أو غير مصرح به.
  - استخدام أدوات تسجيل الدخول لتوثيق الوصول والتغييرات.
- **تحديثات وصيانة منتظمة:**
  - تطبيق التحديثات الأمنية والتصحيحات للبرمجيات المستخدمة في إدارة قواعد البيانات.
- **النسخ الاحتياطي:**
  - إنشاء نسخ احتياطية دورية للبيانات لضمان القدرة على الاستعادة في حالة الفقدان أو التدمير.

---

5. أدوات وتقنيات أمن قواعد البيانات

- **أنظمة إدارة قواعد البيانات :(DBMS)** مثل Oracle وMySQL، التي تحتوي على ميزات أمان مدمجة.
- **جدران الحماية** :لحماية قواعد البيانات من الوصول غير المصرح به.
- **أنظمة الكشف عن التسلل :(IDS)** لمراقبة الأنشطة المشبوهة.